

Relatório de conformidade

Operador Exemplo, Lda · Entidade essencial · situação em 06/10/2026

Decreto-Lei n.º 125/2025 — Regime Jurídico da Segurança do Ciberespaço — ato nacional de transposição da diretiva; este módulo ainda não avalia os seus requisitos

Ferramenta de autoavaliação da ITORO — o documento não constitui uma auditoria nem um parecer jurídico.

Resumo para a administração

ESTATUTO DA ENTIDADE

Entidade essencial

Diretiva NIS 2 artigo 3.º, n.º 1, alínea c),

(fornecedor de redes de comunicações eletrónicas públicas ou de serviços de comunicações eletrónicas acessíveis ao público que seja pelo menos uma média empresa)

GRAU DE PREPARAÇÃO

59%

Maturidade 2.4 com nível-alvo 4

OBRIGAÇÕES FORMAIS

8/16

3 não cumpridas, 5 em curso

Prazos legais mais próximos

- 17/10/2027 (daqui a 376 dias) — Primeira revisão da diretiva pela Comissão

Maiores lacunas

1. Ciber-higiene e formação — maturidade 2.0 face ao objetivo 4, prioridade crítico
2. 7. Políticas e procedimentos para avaliar a eficácia das medidas de gestão dos riscos de cibersegurança [artigo 21.º o , n.º 2, alínea f), da Diretiva (UE) 2022/2555] — maturidade 2.0 face ao objetivo 4, prioridade crítico
3. 9. Criptografia [artigo 21.º o , n.º 2, alínea h), da Diretiva (UE) 2022/2555] — maturidade 2.0 face ao objetivo 4, prioridade crítico
4. 2. Política de gestão dos riscos [artigo 21.º o , n.º 2, alínea a), da Diretiva (UE) 2022/2555] — maturidade 2.2 face ao objetivo 4, prioridade alta
5. 4. Continuidade das atividades e gestão de crises [artigo 21.º o , n.º 2, alínea c), da Diretiva (UE) 2022/2555] — maturidade 2.2 face ao objetivo 4, prioridade alta

As autoridades adquirem o poder de aplicar coimas a partir de 17/10/2024 (Diretiva NIS 2 artigo 41.º, n.º 1). A partir de quando a autoridade nacional pode aplicar coimas é determinado pela lei de transposição da diretiva — este módulo não a conhece. O risco financeiro não é, por isso, datado aqui, enquanto as obrigações de implementação decorrem do direito nacional a partir do dia da sua entrada em vigor.

Responsabilidade financeira

Entidade

Como surge este limite máximo — dois passos distintos

1. O limite máximo mínimo é fixado pela diretiva

Comparam-se dois valores: um montante fixo em euros e uma percentagem do volume de negócios anual total a nível mundial da empresa no exercício anterior. O mais elevado dos dois é o limite superior que o Estado-Membro deve prever no mínimo. O direito nacional pode aumentá-lo.

Diretiva NIS 2 artigo 34.º, n.º 4 e 5

2. O montante dentro do limite máximo é fixado pela autoridade nacional

A coima deve ser efetiva, proporcionada e dissuasiva em função das circunstâncias de cada caso. A autoridade tem em conta pelo menos os critérios do artigo 32.º, n.º 7: a gravidade e a duração da infração, infrações anteriores, os danos causados, a intenção, as medidas corretivas e a cooperação.

Diretiva NIS 2 artigo 34.º, n.º 1 e 3

O limite máximo pode exceder várias vezes o volume de negócios anual — é um limite superior, não um montante esperado. Os mínimos nacionais, as sanções pecuniárias compulsórias e o procedimento de graduação são determinados pela lei do Estado-Membro.

O limite máximo legal da coima é **10 000 000 EUR**. Prevalece o montante fixo: 10 milhões de EUR é mais do que 2 % do volume de negócios.

- Variante percentual: 480 000 EUR
- Variante de montante fixo: 10 000 000 EUR
- Mínimo legal: 0 EUR

Os limites máximos do artigo 34.º, n.os 4 e 5, são mínimos («pelo menos») — o direito nacional pode prever valores mais elevados. Montantes em euros, sem conversão para a moeda nacional.

Graduação da coima — **Diretiva NIS 2** artigo 34.º, n.º 3 e artigo 32.º, n.º 7

Ao decidir se deve ser aplicada uma coima administrativa e o seu montante, são devidamente tidos em conta, em cada caso concreto, pelo menos os elementos enumerados no artigo 32.º, n.º 7.

Critérios do artigo 32.º, n.º 7, da diretiva:

- a gravidade da infração e a importância das disposições violadas — consideram-se graves, em qualquer caso: infrações repetidas, a não notificação ou não correção de incidentes significativos, a não correção de deficiências contrariando instruções vinculativas, a obstrução de auditorias ou da monitorização, a prestação de informações falsas ou grosseiramente inexatas
- czas trwania naruszenia
- quaisquer infrações anteriores pertinentes da entidade
- os danos materiais ou não materiais causados, incluindo perdas financeiras, efeitos noutros serviços e o número de utilizadores afetados
- o caráter doloso ou negligente da infração
- as medidas tomadas para prevenir ou atenuar os danos
- o cumprimento de códigos de conduta ou mecanismos de certificação aprovados
- o grau de cooperação com as autoridades competentes

A diretiva não prevê expressamente a dispensa da coima — se e quando tal é possível é decidido pelo direito nacional.

- Os Estados-Membros podem prever sanções pecuniárias compulsórias para obrigar à cessação de uma infração. O montante é fixado pelo direito nacional.
- A diretiva não prevê uma coima distinta para a infração qualificada — trata-se de uma construção do direito nacional de alguns Estados-Membros.

Responsável da entidade

Ato jurídico	Base	Autoridade	Limite máximo
Diretiva (UE) 2022/2555	Diretiva NIS 2 artigo 20.º, n.º 1	Autoridade competente do Estado-Membro	0 EUR

- O órgão de direção aprova as medidas de gestão dos riscos de cibersegurança (artigo 20.º, n.º 1).
- O órgão de direção supervisiona a implementação dessas medidas (artigo 20.º, n.º 1).
- Os membros do órgão de direção frequentam regularmente formação (artigo 20.º, n.º 2).
- No caso de uma entidade essencial, a autoridade pode solicitar a proibição temporária do exercício de funções de direção (artigo 32.º, n.º 5, alínea b)).

A entidade exerce atividade de comunicações eletrónicas — a responsabilidade do dirigente é determinada pelo direito nacional

As autoridades adquirem o poder de aplicar coimas a partir de **17/10/2024** (**Diretiva NIS 2** artigo 41.º, n.º 1). A partir de quando a autoridade nacional pode aplicar coimas é determinado pela lei de transposição da diretiva — este módulo não a conhece. As obrigações de implementação decorrem do direito nacional a partir do dia da sua entrada em vigor.

2.4

Rozwijany

MATURIDADE GLOBAL

59%

Objetivo: nível 4

GRAU DE CONFORMIDADE

1.6

até ao nível-alvo

LACUNA MÉDIA

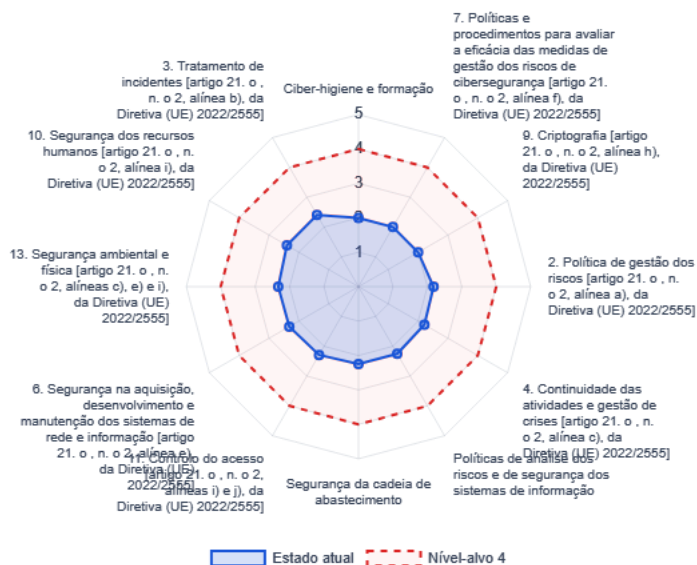
212/212

100 % concluído

RESPOSTAS

Perfil de maturidade

12 áreas com a maior lacuna de 23

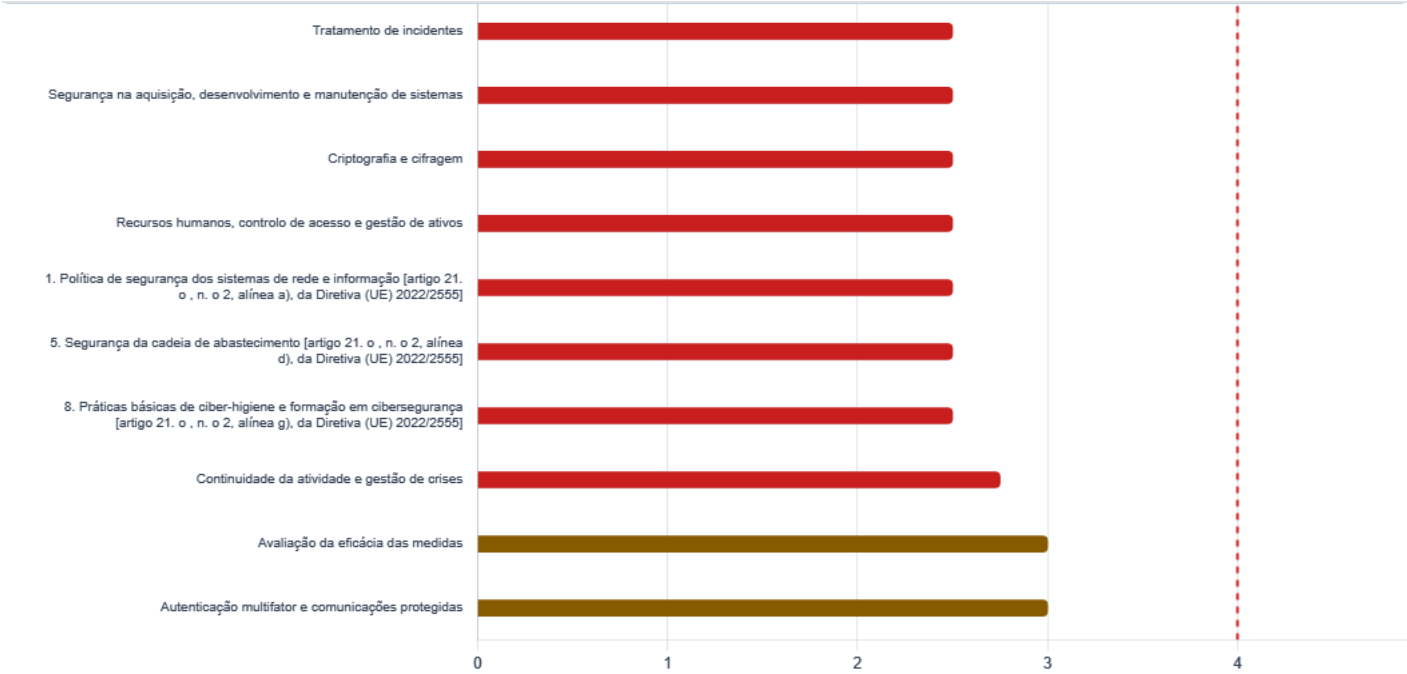


Maturidade por área



Cumprimento por ato jurídico

Ato jurídico	Cumprido	Maturidade
Obrigações Diretiva NIS 2 — obrigações formais	16/16	—
NIS 2 Diretiva NIS 2 — artigo 21.º	35/35	2.5
2024/2690 Regulamento (UE) 2024/2690	161/161	2.3



Análise de lacunas						
Área		Atual	Objetivo	Lacuna	Prioridade	Cumprimento
Ciber-higiene e formação		2.0	4	2.0	Critico	3/3
Diretiva NIS 2	artigo 21.º, n.º 2, alínea g)					
Diretiva NIS 2	artigo 20.º, n.º 2					
7. Políticas e procedimentos para avaliar a eficácia das medidas de gestão dos riscos de cibersegurança [artigo 21. o , n. o 2, alínea f), da Diretiva (UE) 2022/2555]		2.0	4	2.0	Critico	3/3
Regulamento 2024/2690	Anexo, secção 7					
9. Criptografia [artigo 21. o , n. o 2, alínea h), da Diretiva (UE) 2022/2555]		2.0	4	2.0	Critico	3/3
Regulamento 2024/2690	Anexo, secção 9					
2. Política de gestão dos riscos [artigo 21. o , n. o 2, alínea a), da Diretiva (UE) 2022/2555]		2.2	4	1.8	Alta	11/11
Regulamento 2024/2690	Anexo, secção 2					
4. Continuidade das atividades e gestão de crises [artigo 21. o , n. o 2, alínea c), da Diretiva (UE) 2022/2555]		2.2	4	1.8	Alta	14/14
Regulamento 2024/2690	Anexo, secção 4					
Políticas de análise dos riscos e de segurança dos sistemas de informação		2.3	4	1.8	Alta	4/4
Diretiva NIS 2	artigo 21.º, n.º 2, alínea a)					
Segurança da cadeia de abastecimento		2.3	4	1.8	Alta	4/4
Diretiva NIS 2	artigo 21.º, n.º 2, alínea d)					
Diretiva NIS 2	artigo 21.º, n.º 3					
11. Controlo do acesso [artigo 21. o , n. o 2, alíneas i) e j), da Diretiva (UE) 2022/2555]		2.3	4	1.7	Alta	21/21
Regulamento 2024/2690	Anexo, secção 11					
6. Segurança na aquisição, desenvolvimento e manutenção dos sistemas de rede e informação [artigo 21. o , n. o 2, alínea e), da Diretiva (UE) 2022/2555]		2.3	4	1.7	Alta	31/31
Regulamento 2024/2690	Anexo, secção 6					
13. Segurança ambiental e física [artigo 21. o , n. o 2, alíneas c), e) e i), da Diretiva (UE) 2022/2555]		2.3	4	1.7	Alta	9/9
Regulamento 2024/2690	Anexo, secção 13					
10. Segurança dos recursos humanos [artigo 21. o , n. o 2, alínea i), da Diretiva (UE) 2022/2555]		2.4	4	1.6	Alta	10/10
Regulamento 2024/2690	Anexo, secção 10					
3. Tratamento de incidentes [artigo 21. o , n. o 2, alínea b), da Diretiva (UE) 2022/2555]		2.4	4	1.6	Alta	22/22
Regulamento 2024/2690	Anexo, secção 3					
12. Gestão de ativos [artigo 21. o , n. o 2, alínea i), da Diretiva (UE) 2022/2555]		2.5	4	1.5	Alta	13/13
Regulamento 2024/2690	Anexo, secção 12					
Tratamento de incidentes		2.5	4	1.5	Alta	4/4
Diretiva NIS 2	artigo 21.º, n.º 2, alínea b)					
Segurança na aquisição, desenvolvimento e manutenção de sistemas		2.5	4	1.5	Alta	4/4
Diretiva NIS 2	artigo 21.º, n.º 2, alínea e)					
Criptografia e cifragem		2.5	4	1.5	Alta	2/2
Diretiva NIS 2	artigo 21.º, n.º 2, alínea h)					
Recursos humanos, controlo de acesso e gestão de ativos		2.5	4	1.5	Alta	4/4
Diretiva NIS 2	artigo 21.º, n.º 2, alínea i)					
1. Política de segurança dos sistemas de rede e informação [artigo 21. o , n. o 2, alínea a), da Diretiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
Regulamento 2024/2690	Anexo, secção 1					
5. Segurança da cadeia de abastecimento [artigo 21. o , n. o 2, alínea d), da Diretiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
Regulamento 2024/2690	Anexo, secção 5					
8. Práticas básicas de ciber-higiene e formação em cibersegurança [artigo 21. o , n. o 2, alínea g), da Diretiva (UE) 2022/2555]		2.5	4	1.5	Alta	8/8
Regulamento 2024/2690	Anexo, secção 8					
Continuidade da atividade e gestão de crises		2.8	4	1.3	Médio	4/4
Diretiva NIS 2	artigo 21.º, n.º 2, alínea c)					
Avaliação da eficácia das medidas		3.0	4	1.0	Médio	3/3
Diretiva NIS 2	artigo 21.º, n.º 2, alínea f)					

Área	Atual	Objetivo	Lacuna	Prioridade	Cumprimento
Autenticação multifator e comunicações protegidas	3.0	4	1.0	Medio	3/3
Diretiva NIS 2 artigo 21.º, n.º 2, alínea j)					

Registo de riscos jurídicos — obrigações não cumpridas

Obrigação	Base	Prazo	Exposição a sanções
Se a entidade for um prestador de DNS, um registo de nomes de domínio de topo, um prestador de serviços de computação em nuvem, de centro de dados, de CDN, de serviços geridos, um mercado em linha, um motor de pesquisa ou uma rede social — apresentou os dados adicionais do artigo 27.º, incluindo o endereço do estabelecimento principal na União? Dados de registo para a lista de entidades	Diretiva NIS 2 artigo 27.º, n.º 2	—	artigo 34.º
Se a entidade for um prestador de serviços de confiança — notifica os incidentes significativos no prazo de 24 horas após tomar conhecimento? Notificação de incidentes significativos	Diretiva NIS 2 artigo 23.º, n.º 4, segundo parágrafo	24 godziny	artigo 34.º
A entidade essencial está preparada para uma auditoria de segurança realizada pela autoridade ou por um organismo independente, a expensas próprias? Preparação para as medidas de supervisão	Diretiva NIS 2 artigo 32.º, n.º 2, alínea b–c i), n.º 3	—	artigo 32.º, n.º 4

Calendário legal

Data	Evento	Base	Restante
16/01/2023	Entrada em vigor da Diretiva NIS 2 No vigésimo dia seguinte ao da publicação no Jornal Oficial.	Diretiva NIS 2 artigo 45.º	em vigor
17/10/2024	Prazo de transposição da diretiva Até esta data, os Estados-Membros deveriam adotar e publicar as disposições nacionais.	Diretiva NIS 2 artigo 41.º, n.º 1	em vigor
18/10/2024	Aplicação das disposições nacionais e revogação da NIS 1 A partir desta data, os Estados-Membros aplicam as disposições de transposição; a Diretiva (UE) 2016/1148 é revogada.	Diretiva NIS 2 artigo 41.º, n.º 1 e artigo 44.º	em vigor
07/11/2024	Aplicação do Regulamento (UE) 2024/2690 O regulamento de execução é diretamente aplicável a partir do vigésimo dia seguinte ao da publicação.	Regulamento 2024/2690 artigo 16.	em vigor
17/04/2025	Lista de entidades essenciais e importantes Até esta data, os Estados-Membros estabelecem a lista; as entidades apresentam os dados de registo às autoridades.	Diretiva NIS 2 artigo 3.º, n.º 3 e 4	decorrido
17/10/2027	Primeira revisão da diretiva pela Comissão A Comissão reexamina o funcionamento da diretiva e apresenta um relatório.	Diretiva NIS 2 artigo 40.º	376 dias

Limiares de incidente significativo

Para as funções abaixo, os limiares decorrem diretamente do Regulamento (UE) 2024/2690 e aplicam-se desde 7 de novembro de 2024.

Prestadores de serviços de centro de dados (Artigo 8.º)

O conjunto de limiares mais rigoroso de todo o Regulamento. Para os centros de dados NÃO há limiar de 30 minutos NEM limiar de 5 % / 1 milhão de utilizadores — toda a indisponibilidade completa do serviço e toda a violação do acesso físico é um incidente significativo.

- **a)** O serviço de centro de dados está completamente indisponível — SEM limiar temporal.
- **b)** A disponibilidade do serviço está limitada durante mais de 1 hora — SEM limiar percentual ou de número de utilizadores.
- **c)** A integridade, a confidencialidade ou a autenticidade dos dados é comprometida em resultado de uma ação presumivelmente maliciosa.
- **d)** O acesso físico ao centro de dados explorado pelo prestador é comprometido.

Critérios horizontais (artigo 3.º, n.º 1) — basta cumprir um

- **a)** Perda financeira — A perda financeira sofrida ou possível excede 500 000 EUR ou 5 % do volume de negócios anual total da entidade no exercício anterior — consoante o valor mais baixo.
- **b)** Fuga de segredos comerciais — O incidente causou ou é suscetível de causar a exfiltração de segredos comerciais na aceção do artigo 2.º, ponto 1, da Diretiva (UE) 2016/943.
- **c)** Morte de uma pessoa singular — O incidente causou ou é suscetível de causar a morte de uma pessoa singular.
- **d)** Danos consideráveis para a saúde — O incidente causou ou é suscetível de causar danos consideráveis para a saúde de uma pessoa singular.
- **e)** Acesso não autorizado — Ocorreu um acesso bem-sucedido, presumivelmente malicioso e não autorizado a sistemas de rede e de informação, suscetível de causar uma perturbação operacional grave.
- **f)** Incidentes recorrentes — O incidente cumpre os critérios do artigo 4.º: ocorreu pelo menos duas vezes em seis meses, os incidentes têm a mesma causa raiz aparente e cumprem coletivamente o critério de perda financeira do artigo 3.º, n.º 1, alínea a). São considerados coletivamente um incidente significativo.
- **g)** Critério setorial — O incidente cumpre pelo menos um dos critérios setoriais estabelecidos nos artigos 5.º a 14.º do Regulamento.

Atividade de comunicações eletrónicas — os limiares são fixados pelo direito nacional. O Regulamento (UE) 2024/2690 não se aplica aos fornecedores de redes e serviços de comunicações eletrónicas públicos. Para estes, os limiares de incidente significativo são fixados pelo direito nacional (artigo 23.º, n.º 11, da diretiva) — este módulo não os conhece e, por isso, não apresenta valores.

Histórico e progresso

Ainda não foi guardado nenhum instantâneo. Um instantâneo congela o estado atual da avaliação juntamente com a data, para que os relatórios seguintes mostrem o progresso.

Guardar o primeiro instantâneo